

REPORT SCANSIONE VULNERABILITÀ CON NESSUS

Metasploitable – Vulnerability Assessment e Remediation

Strumento	Nessus – Basic Network Scan
Sistema analizzato	Metasploitable
IP	192.168.60.101
Obiettivo	Scansione, remediation e verifica finale

Obiettivo dell'esercitazione

L'obiettivo è stato eseguire una scansione completa della macchina Metasploitable tramite Nessus, individuare vulnerabilità Critical, applicare alcune azioni di remediation e ripetere la scansione per verificare il risultato.

Configurazione del laboratorio

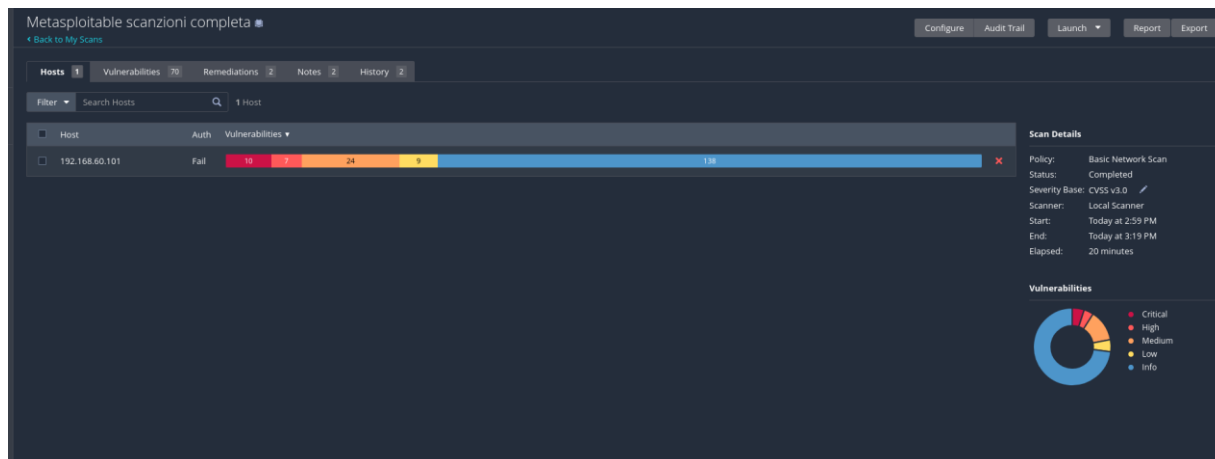
La macchina analizzata è Metasploitable con indirizzo IP 192.168.60.101. È stata utilizzata la policy Basic Network Scan con lo scanner locale di Nessus.

L'autenticazione risultava Fail, quindi la scansione è stata eseguita senza autenticazione al sistema.

La scansione iniziale ha rilevato 70 vulnerabilità: 10 Critical, 7 High, 24 Medium e 9 Low, oltre agli elementi informativi.

Scansione iniziale e scelta delle vulnerabilità

Tra le vulnerabilità Critical individuate sono state selezionate due problematiche sulle quali effettuare la remediation: VNC Server 'password' Password, CVSS 10.0, e SSL Version 2 and 3 Protocol Detection, CVSS 9.8.



Riepilogo della scansione iniziale Nessus: 70 vulnerabilità rilevate sull'host 192.168.60.101.

Filter	Search Vulnerabilities		70 Vulnerabilities				
Sev	CVSS	VPR	EPSS	Name	Family	Count	
☐ CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8.04.x)	General	1	
☐ CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1	
☐ CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2	
☐ CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1	
☐ MIXED	...	...	...	Apache Tomcat (Multiple Issues)	Web Servers	4	
☐ CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3	
☐ HIGH	7.5	4.9	0.3693	Samba Badlock Vulnerability	General	1	
☐ HIGH	7.5 *	4.9	0.119	rlogin Service Detection	Service detection	1	
☐ HIGH	7.5 *	4.9	0.119	rsh Service Detection	Service detection	1	
☐ HIGH	7.5			NFS Shares World Readable	RPC	1	
☐ MIXED	...	...	...	SSL (Multiple Issues)	General	28	
☐ MIXED	...	...	...	ISC Bind (Multiple Issues)	DNS	5	
☐ MEDIUM	6.5			TLS Version 1.0 Protocol Detection	Service detection	2	
☐ MEDIUM	6.5			Unencrypted Telnet Server	Misc.	1	

Elenco delle principali vulnerabilità rilevate nella scansione iniziale, incluse le vulnerabilità Critical selezionate per la remediation.

Per la vulnerabilità SSL, il dettaglio di Nessus mostra che SSLv2 era abilitato sul servizio SMTP della porta 25/tcp e SSLv3 sul servizio PostgreSQL della porta 5432/tcp. Nessus raccomanda di disabilitare SSL 2.0 e SSL 3.0 e utilizzare TLS 1.2 o superiore.

CRITICAL

SSL Version 2 and 3 Protocol Detection

<

Description

The remote service accepts connections encrypted using SSL 2.0 and/or SSL 3.0. These versions of SSL are affected by several cryptographic flaws, including:

- An insecure padding scheme with CBC ciphers.
- Insecure session renegotiation and resumption schemes.

An attacker can exploit these flaws to conduct man-in-the-middle attacks or to decrypt communications between the affected service and clients.

Although SSL/TLS has a secure means for choosing the highest supported version of the protocol (so that these versions will be used only if the client or server support nothing better), many web browsers implement this in an unsafe way that allows an attacker to downgrade a connection (such as in POODLE). Therefore, it is recommended that these protocols be disabled entirely.

NIST has determined that SSL 3.0 is no longer acceptable for secure communications. As of the date of enforcement found in PCI DSS v3.1, any version of SSL will not meet the PCI SSC's definition of 'strong cryptography'.

Solution

Consult the application's documentation to disable SSL 2.0 and 3.0.

Use TLS 1.2 (with approved cipher suites) or higher instead.

See Also

<https://www.schneier.com/academic/paperfiles/paper-ssl.pdf>
<http://www.nessus.org/u7b06c7e95>
<http://www.nessus.org/u7247c4540>
<https://www.openssl.org/~bodo/ssl-poodle.pdf>
<http://www.nessus.org/u75d15ba70>
<https://www.imperialviolet.org/2014/10/14/poodle.html>
<https://tools.ietf.org/html/rfc7507>
<https://tools.ietf.org/html/rfc7568>

Dettaglio Nessus della vulnerabilità Critical “SSL Version 2 and 3 Protocol Detection”.

Output

- SSLv2 is enabled and the server supports at least one cipher.

Low Strength Ciphers (<= 64-bit key)

Name	Code	KEX	Auth	Encryption	MAC	
EXP-RC2-CBC-MD5		RSA	RSA	RC2-CBC(40)	MD5	export
EXP-RC4-MD5		RSA	RSA	RC4(40)	MD5	export

more...

To see debug logs, please visit individual host

Port ▲

Hosts

25 / tcp / smtp	192.168.60.101	
-----------------	----------------	--

- SSLv3 is enabled and the server supports at least one cipher.

Explanation: TLS 1.0 and SSL 3.0 cipher suites may be used with SSLv3

Medium Strength Ciphers (> 64-bit and < 112-bit key, or 3DES)

Name	Code	KEX	Auth	Encryption	MAC	
EXP-RC2-CBC-MD5		RSA	RSA	RC2-CBC(40)	MD5	export
EXP-RC4-MD5		RSA	RSA	RC4(40)	MD5	export

more...

To see debug logs, please visit individual host

Port ▲

Hosts

5432 / tcp / postgresql	192.168.60.101	
-------------------------	----------------	--

Output Nessus relativo ai protocolli SSLv2/SSLv3 rilevati sulle porte 25/tcp e 5432/tcp.

Vulnerabilities
70

Filter
NFS
2 of 70 Vulnerabilities

	Sev	CVSS	VPR	EPSS	Name	Family	Count	
☐	HIGH	7.5			NFS Shares ...	RPC	1	
☐	INFO				NFS Share Ex...	RPC	1	

Results per page
50
Showing: 1 to 2 of 2

Filtro Nessus “NFS”: vengono visualizzati due finding NFS, tra cui “NFS Shares World Readable” con severità High.

L'analisi ha inoltre evidenziato due finding relativi a NFS. Il finding “NFS Shares World Readable” è classificato High, mentre il secondo elemento è informativo; tali evidenze confermano la presenza di condivisioni NFS esposte sul sistema.

Remediation della vulnerabilità VNC

La prima remediation ha riguardato VNC Server 'password' Password. Nessus aveva rilevato che il servizio VNC poteva essere autenticato con la password debole 'password'.

Metasploitable scansioni completa / Plugin #61708
Configure
Audit Trail
Launch
Report
Export

Vulnerabilities
70

CRITICAL
VNC Server 'password' Password

Description
The VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system.
Solution
Secure the VNC service with a strong password.
Output
Nessus logged in using a password of "password".
To see debug logs, please visit individual host
Port
Hosts
5900 / tcp / vnc
192.168.60.101

Plugin Details
Severity: Critical
ID: 61708
Version: \$Revision: 1.2 \$
Type: remote
Family: Gain a shell remotely
Published: August 29, 2012
Modified: September 24, 2015
Risk Information
Risk Factor: Critical
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C
Vulnerability Information
Default Account: true
Exploited by Nessus: true

Plugin Nessus VNC Server 'password' Password, CVSS 10.0, porta 5900/tcp.

Il dettaglio del plugin mostra che Nessus è riuscito ad autenticarsi al servizio VNC utilizzando la password “password”. La remediation prevista consiste nell'impostare una password robusta.

Sul Metasploitable è stata modificata la password del file VNC con:

```
sudo vncpasswd /root/.vnc/passwd
```

Dopo la modifica, il servizio VNC è stato riavviato per applicare la nuova configurazione.

Remediation della vulnerabilità SSL

Per la seconda vulnerabilità è stata applicata una remediation tramite firewall, modalità prevista dalla traccia dell'esercitazione. Sono state bloccate in ingresso le porte associate ai servizi indicati dal finding Nessus.

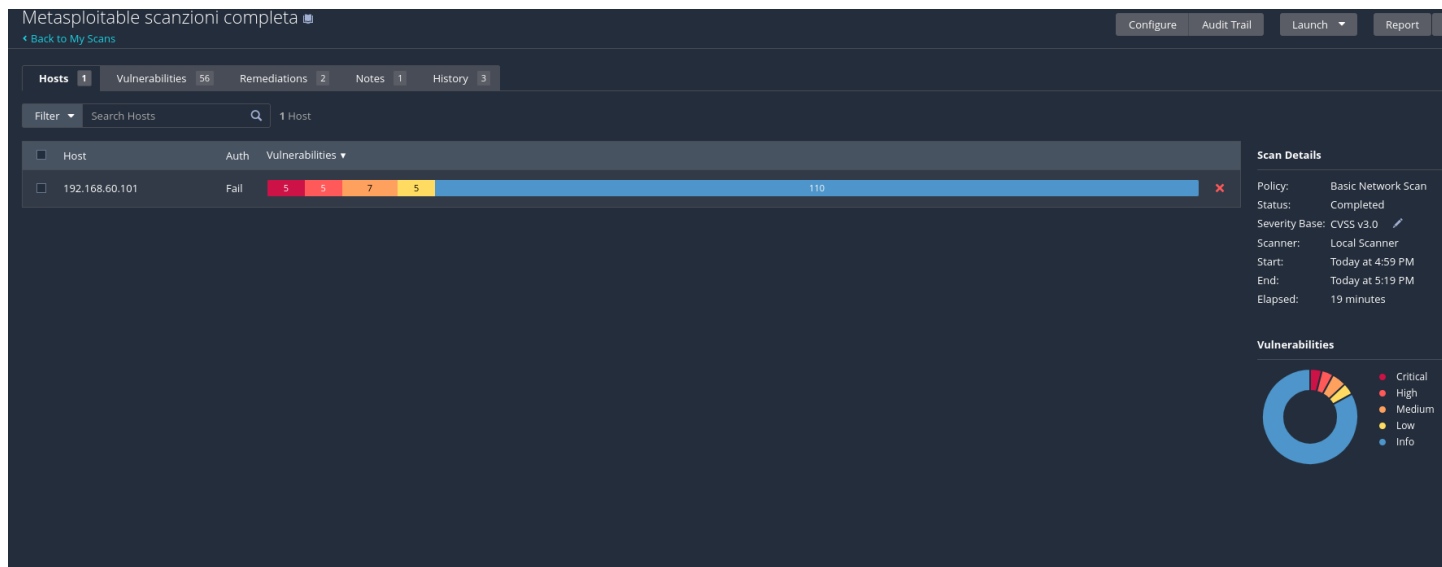
```
sudo iptables -A INPUT -p tcp --dport 25 -j DROP
```

```
sudo iptables -A INPUT -p tcp --dport 5432 -j DROP
```

I due comandi non hanno restituito errori. La modifica è stata quindi applicata prima della scansione finale.

Scansione finale

Dopo le remediation è stata eseguita una nuova scansione Nessus sullo stesso host 192.168.60.101. La scansione è terminata con stato Completed.



Riepilogo della scansione finale Nessus: 56 vulnerabilità rilevate dopo la remediation.

Il risultato finale mostra 56 vulnerabilità complessive: 5 Critical, 5 High, 7 Medium e 5 Low, oltre a 110 elementi informativi.

Filter

Search Vulnerabilities

56 Vulnerabilities

Sev	CVSS	VPR	EPSS	Name	Family	Count	
☐	CRITICAL	10.0 *	6.0	0.7072	Debian OpenSSH/OpenSSL Package Random Number Generator Weakness	Gain a shell remotely	1
☐	CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8.04.x)	General	1
☐	CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1
☐	MIXED	...	...	...	Apache Tomcat (Multiple Issues)	Web Servers	4
☐	HIGH	7.5	4.9	0.3693	Samba Badlock Vulnerability	General	1
☐	HIGH	7.5 *	4.9	0.119	rlogin Service Detection	Service detection	1
☐	HIGH	7.5 *	4.9	0.119	rsh Service Detection	Service detection	1
☐	HIGH	7.5			NFS Shares World Readable	RPC	1
☐	MIXED	...	...	...	ISC Bind (Multiple Issues)	DNS	5
☐	MEDIUM	6.5			Unencrypted Telnet Server	Misc.	1
☐	MIXED	...	...	...	SSH (Multiple Issues)	Misc.	6
☐	MIXED	...	...	...	HTTP (Multiple Issues)	Web Servers	5
☐	MIXED	...	...	...	SMB (Multiple Issues)	Misc.	2
☐	LOW	2.6 *			X Server Detection	Service detection	1

Host Details

IP:

192.168.60.101

OS:

Linux Kernel 2.6 on Ubuntu 8.04 (hardy)

Start:

Today at 4:59 PM

End:

Today at 5:19 PM

Elapsed:

19 minutes

KB:

[Download](#)

Auth:

Fail

Vulnerabilities

Critical

High

Medium

Low

Info

Elenco delle vulnerabilità presenti nella scansione finale; le due vulnerabilità selezionate non risultano più nell'elenco.

Dalle schermate di riepilogo si osserva il passaggio da 70 a 56 vulnerabilità complessive. Le categorie passano da 10 a 5 Critical, da 7 a 5 High, da 24 a 7 Medium e da 9 a 5 Low; gli elementi informativi passano da 138 a 110.

Confronto prima e dopo

Elemento	Inizio	Fine
Vulnerabilità totali	70	56
Critical	10	5
High	7	5
Medium	24	7
Low	9	5
VNC Server 'password' Password	Presente	Non presente nell'elenco finale
SSL Version 2 and 3 Protocol Detection	Presente	Non presente nell'elenco finale

Il confronto mostra una riduzione delle vulnerabilità complessive e delle Critical. In particolare, le due vulnerabilità selezionate per la remediation non compaiono più nell'elenco finale mostrato da Nessus.

Nella scansione finale rimangono comunque altre vulnerabilità Critical, tra cui Debian OpenSSH/OpenSSL Package Random Number Generator Weakness, Canonical Ubuntu Linux SeOL (8.04.x) e Bind Shell Backdoor Detection. Queste non sono state trattate nella presente esercitazione.

Conclusioni

L'esercitazione ha permesso di eseguire un vulnerability assessment con Nessus, individuare vulnerabilità Critical, applicare interventi di remediation e verificarne l'esito con una nuova scansione.

Le due vulnerabilità selezionate, VNC Server 'password' Password e SSL Version 2 and 3 Protocol Detection, non risultano più nell'elenco della scansione finale. La remediation è quindi stata verificata tramite il confronto tra la scansione iniziale e quella finale.

Nota metodologica: le conclusioni del report si basano esclusivamente sulle evidenze mostrate nelle schermate Nessus fornite per la pratica. La scansione finale risulta "Completed" e riferita allo stesso host 192.168.60.101.